

Cloud Storage Advisory

Virtual Village — AI Presence Monitoring System

Transitioning from VV Hub to HIPAA-Compliant Public Cloud Storage

UTD Capstone Project | Spring 2026 | CONFIDENTIAL

⚠ Important Disclaimer

This document is an advisory guide prepared for the Virtual Village capstone project. It does not constitute legal advice.

HIPAA compliance is a legal obligation. Before deploying any system that handles Protected Health Information (PHI)

or personally identifiable sensor data in a production environment, consult a qualified HIPAA compliance officer

and/or legal counsel. Requirements may evolve — always verify against the latest HHS guidance.

Table of Contents

- Overview & Purpose
- Does VV Data Qualify as PHI?
- Regulatory Framework
 - HIPAA, HITECH, and State Law
 - FTC Health Breach Notification Rule
- Cloud Provider Comparison
 - AWS (Recommended)
 - Microsoft Azure
 - Google Cloud Platform
- AWS — Detailed Configuration Guide
- Required Security Controls
- Data Classification & Handling
- Business Associate Agreement (BAA)
- Incident Response & Breach Notification
- Migration Checklist from VV Hub
- Decision Summary & Recommendation

Overview & Purpose

The Virtual Village system collects continuous mmWave radar readings from a senior resident's home across 6 rooms over extended periods. As the project scales beyond a local hub (VV Hub)

toward a hosted or cloud-based architecture, the storage and transmission of this data must comply with applicable health privacy regulations.

This advisory evaluates three major cloud platforms — AWS, Microsoft Azure, and Google Cloud — and provides specific configuration guidance for transitioning to HIPAA-compliant public cloud storage. It also outlines the minimum security controls, access policies, and legal agreements required before any such transition.

i Scope of This Document

This advisory covers: cloud storage selection, HIPAA/HITECH requirements, security controls, Business Associate Agreements, data classification, and a migration checklist from VV Hub. It does not cover: network infrastructure, application-layer security, or caregiver-facing app compliance.

Does VV Data Qualify as PHI?

Under HIPAA, Protected Health Information (PHI) is any individually identifiable health information created, received, maintained, or transmitted by a covered entity or business associate. The answer for VV data depends on deployment context.

Data Element	PHI Status & Rationale
Radar sensor readings (x, y, z, motion)	Potential PHI — if linkable to a named individual in a care setting, positional and behavioral data constitutes health information.
z_height / posture classification	Potential PHI — inferred health behavior (sleeping, lying down, falling) that relates to functional status of an identified person.
Room occupancy & timestamps	Potential PHI — detailed location + time data tied to a resident's daily routine is individually identifiable in context.
Alert events (fall, inactivity)	Likely PHI — explicit health-related event records linked to a specific resident.
sensor_data.csv / JSON files	Likely PHI — aggregated file containing all of the above for an identified individual.
Model outputs / predictions	Likely PHI — derived health status inferences (posture, activity level) about a specific person.

⚠ Key Determination

Even if the current dataset uses anonymized sensor IDs, in a real deployment the data is tied to a specific named resident in a specific address. Under HIPAA's definition, this makes it PHI. Treat all VV sensor data as PHI from the moment any linkage to a real individual exists.

Regulatory Framework

HIPAA — Health Insurance Portability and Accountability Act

HIPAA is the primary U.S. federal law governing PHI. For VV, the two most relevant rules are:

Security Rule

Requires covered entities and business associates to implement administrative, physical, and technical safeguards to protect ePHI (electronic PHI). Key requirements include:

- Access controls — unique user identification, automatic logoff, encryption
- Audit controls — hardware, software, and procedural mechanisms to record activity
- Integrity controls — ensure ePHI is not improperly altered or destroyed
- Transmission security — encryption of ePHI in transit (TLS 1.2+)

Privacy Rule

Governs the use and disclosure of PHI. Key points for VV:

- Data may only be used for treatment, payment, or healthcare operations without explicit authorization
- Minimum necessary standard — only the data needed for the stated purpose should be accessed or shared
- Resident (or their authorized representative) must be notified of data practices via a Notice of Privacy Practices

HITECH — Health Information Technology for Economic and Clinical Health Act

Strengthens HIPAA enforcement and extends obligations to Business Associates (e.g., cloud providers). Key additions:

- Mandatory breach notification to affected individuals, HHS, and media (if >500 in a state) within 60 days
- Increased civil and criminal penalties — up to \$1.9M per violation category per year
- Business Associates are directly liable for HIPAA violations — the cloud provider you choose becomes a BA

FTC Health Breach Notification Rule

Applies to vendors of personal health records (PHRs) and their service providers — particularly relevant if VV expands to a consumer-facing app. Requires breach notification within 60 days regardless of HIPAA coverage.

State-Level Laws

Several states have enacted health privacy laws stricter than HIPAA. Notable examples relevant to a Texas-based deployment:

- Texas Medical Records Privacy Act (TMRPA) — applies to any person who creates, uses, or discloses protected health information; broader than HIPAA's covered entity definition
- California CMIA (Confidentiality of Medical Information Act) — applies if any California residents are served
- Illinois BIPA — biometric data law; may apply if radar data is interpreted as gait/behavioral biometrics

Cloud Provider Comparison

All three major cloud providers offer HIPAA-eligible services and will sign a Business Associate Agreement (BAA). However, they differ significantly in configuration complexity, cost, and healthcare-specific tooling.

Factor	AWS	Microsoft Azure	Google Cloud
BAA Available	✓ Yes	✓ Yes	✓ Yes
HIPAA-Eligible Services	150+ services	100+ services	100+ services
Healthcare-Specific Tools	AWS HealthLake, Macie	Azure Health Data Services	Cloud Healthcare API
Storage Service	S3 + Glacier	Blob Storage + Archive	Cloud Storage
Encryption at Rest	AES-256 default	AES-256 default	AES-256 default
Key Management	AWS KMS (CMK)	Azure Key Vault	Cloud KMS / CMEK
Audit Logging	CloudTrail + S3 Logs	Azure Monitor + Defender	Cloud Audit Logs
Access Control	IAM + SCPs	Azure AD + RBAC	IAM + Org Policy
Data Residency (US)	✓ Strong	✓ Strong	Good
Compliance Certifications	HIPAA, SOC 2, FedRAMP	HIPAA, SOC 2, FedRAMP	HIPAA, SOC 2, FedRAMP
Estimated Cost (small)	~\$5–20/mo	~\$5–20/mo	~\$5–18/mo
Recommended For VV	★ Top Pick	Strong Alternative	Strong Alternative

✓ Recommendation: AWS S3

AWS is the recommended platform for VV based on its mature HIPAA program, most comprehensive list of HIPAA-eligible services, strongest IAM controls, and widest adoption in the healthcare sensor/IoT space. AWS also offers Amazon Macie for automated PHI detection in S3 buckets. Microsoft Azure is a strong alternative, especially if the team already uses Microsoft tools.

AWS — Detailed Configuration Guide

Step 1: Sign a Business Associate Agreement

Before storing any PHI in AWS, you must execute a BAA with Amazon. This is done through the AWS Artifact console — it is a self-service agreement, not a negotiated contract.

- Log in to AWS Console → AWS Artifact → Agreements → HIPAA BAA → Accept
- The BAA covers all HIPAA-eligible services used in the same AWS account
- Ensure only HIPAA-eligible services are used — a full list is published at aws.amazon.com/compliance/hipaa-eligible-services-reference

Step 2: Create a Dedicated S3 Bucket

- Create a bucket in a U.S. region (us-east-1 or us-west-2 recommended for data residency)
- Naming: use a non-descriptive name — avoid names like 'vv-patient-data' that reveal the bucket's PHI contents
- Block ALL public access — enable all four Block Public Access settings at the bucket level
- Enable versioning — protects against accidental deletion or ransomware overwrites
- Enable Object Lock (WORM) for audit logs and alert records — prevents modification or deletion

Step 3: Encryption Configuration

Setting	Required Configuration
Encryption at Rest	Enable SSE-KMS (Server-Side Encryption with AWS KMS Customer Managed Key). Do NOT use SSE-S3 for PHI — CMKs provide auditable key usage logs.
Encryption in Transit	Enforce HTTPS only via S3 bucket policy: deny all s3:* actions where aws:SecureTransport = false
KMS Key Policy	Restrict key usage to specific IAM roles only. Enable key rotation (automatic, annual minimum). Log all key usage via CloudTrail.
Client-Side Encryption	Recommended for the highest sensitivity data (alert events, posture records). Encrypt before upload using AWS Encryption SDK.

Step 4: IAM Access Controls

Apply the principle of least privilege — no user or service should have more access than their role requires.

- Create a dedicated IAM role for the VV application — grant only s3:GetObject, s3:PutObject, s3:DeleteObject on the specific bucket ARN
- No root account access to the VV bucket — disable root access keys entirely
- Enable MFA Delete on the S3 bucket — requires MFA to permanently delete objects

- Use IAM Conditions to restrict access by IP range (e.g., only the VV server's IP can write data)
- Enable AWS IAM Access Analyzer — automatically detects unintended public or cross-account access

Step 5: Audit Logging & Monitoring

- Enable AWS CloudTrail in all regions — logs every API call including S3 access, IAM changes, and KMS key usage
- Enable S3 Server Access Logging — logs all requests made to the VV bucket including requester, IP, action
- Configure CloudWatch Alarms for: unauthorized access attempts, bucket policy changes, large data downloads, MFA Delete attempts
- Enable Amazon Macie — automatically scans S3 buckets for PHI and sensitive data patterns, generates findings for review
- Retain logs for minimum 6 years (HIPAA requirement for covered entities)

Step 6: Network Security

- Use VPC Endpoints for S3 — ensures data never traverses the public internet between your application and S3
- Enable S3 Object Ownership (Bucket Owner Enforced) — prevents object ACLs and enforces bucket-level policy
- Configure AWS Config rules to continuously check: s3-bucket-public-read-prohibited, s3-bucket-server-side-encryption-enabled, s3-bucket-ssl-requests-only

Step 7: Backup & Disaster Recovery

- Enable Cross-Region Replication to a secondary U.S. region (e.g., us-east-1 → us-west-2)
- Set up S3 Lifecycle policies: move data to S3 Intelligent-Tiering after 30 days, Glacier after 1 year
- Test restoration procedures quarterly — HIPAA requires demonstrated ability to restore data
- Maintain a Recovery Time Objective (RTO) and Recovery Point Objective (RPO) in your contingency plan

Required Security Controls

The following controls are required under HIPAA's Security Rule. All must be documented and reviewed annually.

Control Category	Required Implementation
Access Control	Unique user IDs for all system users. Role-based access (no shared credentials). Automatic session timeout after 15 minutes of inactivity. MFA required for all administrative access.
Audit Controls	CloudTrail enabled across all regions. S3 access logs retained for 6+ years. Regular log reviews (monthly minimum). Automated alerts for anomalous access patterns.
Integrity Controls	S3 Object Lock (WORM mode) for immutable records. Enable S3 Versioning. Use SHA-256 checksums on upload (S3 Content-MD5 header). Data validation checks on ingestion.
Transmission Security	TLS 1.2 minimum for all data in transit (TLS 1.3 recommended). S3 bucket policy denies HTTP requests. VPC Endpoints eliminate public internet exposure. Certificate pinning for application connections.
Encryption at Rest	AES-256 via AWS KMS CMK. Customer-managed key rotation enabled (annual). Key usage logged via CloudTrail. Separate KMS keys per data classification tier.
Workforce Controls	Security awareness training for all personnel with data access. Background checks for staff handling PHI. Signed confidentiality agreements. Access revocation procedure on role change.
Physical Safeguards	AWS data centers are SOC 2 / ISO 27001 certified — physical controls are AWS responsibility under the shared responsibility model. Document this in your risk assessment.
Risk Analysis	Conduct and document a formal HIPAA Risk Analysis before go-live. Review annually or after any significant system change. Address all identified risks with documented mitigation.

Data Classification & Handling

Not all VV data carries the same sensitivity. Classify data before migration to apply appropriate controls and avoid over-engineering lower-risk assets.

Classification	VV Data Examples & Handling Requirements
HIGH — PHI	Alert events (fall detected, inactivity), posture classifications linked to a resident, sensor_data.csv with timestamps. Encrypt with CMK. Strict IAM. Audit all access. Breach notification applies.
MEDIUM — De-identified Sensor Data	Raw radar readings with sensor UUIDs (if UUIDs cannot be reverse-linked to a person). Encrypt at rest. Access logging required. Not subject to HIPAA if truly de-identified per Safe Harbor standard.
LOW — Model Artifacts	Trained model files (.pkl), feature importance charts, EDA dashboards (no resident data). Standard S3 encryption. No PHI obligations if no resident data embedded.
PUBLIC — Documentation	Architecture diagrams, requirements.txt, anonymized code. Can use public S3 bucket or GitHub. No PHI controls required.

i De-identification Standard (HIPAA Safe Harbor)

Data is considered de-identified under HIPAA Safe Harbor only if ALL 18 identifiers are removed, including: names, dates (except year), geographic data smaller than state, ages over 89, and any other unique identifiers. Sensor UUIDs that map to a specific home location do NOT qualify as de-identified without additional transformation.

Business Associate Agreement (BAA)

A BAA is a legally required contract between a HIPAA-covered entity (or Business Associate) and any vendor that handles PHI on their behalf. The cloud provider storing VV data becomes a Business Associate and must sign a BAA before receiving any PHI.

What the BAA Must Cover

- Permitted uses and disclosures of PHI by the BA
- Requirement that the BA implement HIPAA-required safeguards
- Obligation to report breaches to the covered entity within 60 days
- Requirement to return or destroy PHI upon contract termination
- Right of the covered entity to audit the BA's compliance

BAA Process per Provider

Provider	BAA Process
AWS	Self-service via AWS Artifact console. Free. Covers all HIPAA-eligible services in the account. Execute before any PHI upload.
Microsoft Azure	Available via Microsoft's Online Services Terms or through your Microsoft account team. Covers Azure HIPAA-eligible services.
Google Cloud	Available through Google Cloud's Data Processing Agreement. Execute via GCP Console under IAM → Data Processing.

⚠ BAA Does Not Equal Compliance

Signing a BAA transfers contractual obligation to the provider for their infrastructure — it does NOT mean your implementation is automatically HIPAA compliant. You remain responsible for correct configuration, access controls, encryption settings, and all application-layer security.

Incident Response & Breach Notification

Breach Definition

A breach is any unauthorized acquisition, access, use, or disclosure of unsecured PHI that compromises its security or privacy. Under HITECH, the presumption is that any impermissible access IS a breach unless the covered entity can demonstrate a low probability that PHI was compromised.

Notification Timelines

Recipient	Timeline & Requirements
Affected Individuals	Written notice within 60 days of discovery. Must include: description of breach, types of PHI involved, steps taken, contact information.
HHS (Secretary)	If >500 individuals: within 60 days of discovery. If <500: log and report annually within 60 days of year end. File at hhs.gov/hipaa/for-professionals/breach-notification .
Media	If >500 residents of a state or jurisdiction are affected: notify prominent media outlets in that state within 60 days.
Business Associates	Must notify the covered entity within 60 days of discovery of a breach at the BA level.

Minimum Incident Response Plan Elements

1. Detection — AWS GuardDuty, Macie, and CloudWatch Alarms trigger on anomalous access
2. Containment — revoke compromised IAM credentials, block offending IPs via Security Groups, preserve logs
3. Assessment — determine what PHI was accessed, by whom, for how long
4. Notification — follow timelines above; document all steps taken
5. Remediation — patch the vulnerability, rotate credentials, update controls
6. Post-Incident Review — document lessons learned; update risk analysis

Migration Checklist: VV Hub → Cloud

Complete all items before moving any production or resident-linked data to the cloud.

Pre-Migration — Legal & Administrative

- ☐ Execute BAA with chosen cloud provider
- ☐ Conduct and document HIPAA Risk Analysis for new architecture
- ☐ Update Notice of Privacy Practices to reflect cloud storage
- ☐ Obtain resident (or authorized representative) consent for cloud-based storage if required by state law
- ☐ Establish data retention and destruction policy (HIPAA minimum: 6 years for covered entities)

Pre-Migration — Technical

- ☐ Create dedicated AWS account or OU for VV PHI workload (isolate from other environments)
- ☐ Configure S3 bucket with all public access blocked
- ☐ Enable SSE-KMS with Customer Managed Key; configure key rotation
- ☐ Apply bucket policy enforcing HTTPS-only access
- ☐ Enable S3 Versioning and Object Lock
- ☐ Configure IAM roles with least-privilege policies
- ☐ Enable MFA Delete
- ☐ Enable CloudTrail (all regions), S3 Server Access Logging, and AWS Config
- ☐ Deploy Amazon Macie on the VV bucket
- ☐ Configure VPC Endpoint for S3
- ☐ Set up CloudWatch Alarms for unauthorized access and large downloads
- ☐ Test encryption, access controls, and logging in a non-PHI staging environment

Migration

- ☐ Use AWS DataSync or AWS Transfer Family for secure, logged data transfer from VV Hub
- ☐ Verify checksums after transfer — confirm no data corruption
- ☐ Confirm all transferred data is encrypted at rest (check KMS key assignment)
- ☐ Verify no objects are publicly accessible (Macie scan)

Post-Migration

- ☐ Securely wipe VV Hub storage after confirming cloud integrity
- ☐ Document the migration in your HIPAA audit trail
- ☐ Schedule quarterly access reviews and annual risk analysis update
- ☐ Test disaster recovery restoration procedure
- ☐ Train all system users on new access procedures

Decision Summary & Recommendation

★ Recommended Path: AWS S3 with HIPAA Controls	
Platform:	Amazon Web Services (AWS)
Storage:	Amazon S3 (us-east-1, primary) + us-west-2 (cross-region replication)
Encryption:	SSE-KMS with Customer Managed Key + HTTPS-only policy
Access:	IAM roles with least privilege, MFA Delete, VPC Endpoints
Monitoring:	CloudTrail + S3 Access Logs + Macie + CloudWatch Alarms

Compliance: Execute BAA via AWS Artifact before any PHI upload
Estimated Cost: \$10–25/month for VV data volume at current scale

This configuration provides full HIPAA Security Rule compliance, automated PHI detection, comprehensive audit logging, and a clear chain of custody for all sensor data. The AWS BAA covers the infrastructure layer; your team remains responsible for application-layer security, access management, and documented compliance practices.

i For the Capstone Submission

If this system is not yet in production use with a real named resident, strict HIPAA obligations may not apply to the current research prototype. However, adopting these controls now ensures the system is production-ready and demonstrates responsible data engineering practice — both important criteria for a capstone project in the healthcare AI space.

AWS Shared Responsibility Model

One of the most commonly misunderstood aspects of cloud compliance is the division of responsibility between AWS and the customer. Signing a BAA does not mean AWS handles your HIPAA compliance — it means AWS secures the infrastructure while you remain responsible for everything built on top of it.

AWS Responsibility (Security OF the Cloud)	Your Responsibility (Security IN the Cloud)
Physical data center security (access, surveillance, power)	S3 bucket configuration (blocking public access, versioning)
Hardware and host infrastructure maintenance	Encryption settings (SSE-KMS, HTTPS-only policy)
Hypervisor and network infrastructure	IAM users, roles, policies, and MFA enforcement
Availability zones and global infrastructure resilience	Application-layer security and authentication
Compliance of AWS services themselves (SOC 2, ISO 27001)	Your own HIPAA Risk Analysis and documentation
Hardware destruction at end-of-life	Data classification and access control design
DDoS protection at network layer (AWS Shield Standard)	Monitoring, alerting, and incident response procedures
Patching of managed services (RDS, Lambda, etc.)	Patching your own EC2 instances and application code

⚠ Critical Point

A misconfigured S3 bucket — even one running on HIPAA-eligible AWS infrastructure under a valid BAA — is a HIPAA violation for which YOU are liable. AWS is not responsible for customer misconfiguration. The majority of healthcare cloud breaches are caused by customer-side misconfiguration, not AWS failures.

Recommended Data Architecture on AWS

S3 Bucket Structure

Organize your S3 bucket with a clear folder hierarchy that reflects data classification, sensor source, and time period. This enables precise IAM policies, lifecycle rules, and audit queries.

```
vv-presence-phi-prod/
  raw/                  ← presence_data_4.json and future JSON uploads
  processed/            ← sensor_data.csv, feature-engineered files
    YYYY/MM/DD/        ← date-partitioned for lifecycle management
  predictions/          ← model output CSVs per run
  alerts/               ← alert event records (highest sensitivity)
  models/               ← trained .pkl model files
  dashboards/           ← EDA output images
(VirtualVillage_EDA_Dashboard.png)
  logs/                 ← application-generated logs (separate from
CloudTrail)
  archive/              ← Glacier-transitioned older data
```

Tagging Strategy

Apply consistent tags to all AWS resources. Tags enable cost allocation, compliance reporting, and automated policy enforcement via AWS Config.

Tag Key	Example Value & Purpose
Project	VirtualVillage — identifies all VV resources for cost tracking
DataClassification	PHI Confidential Internal Public — drives automated controls
Environment	prod staging dev — prevents cross-environment access
Owner	team@utd.edu — accountability for each resource
HIPAAScope	true false — flags resources in scope for HIPAA audits
RetentionYears	6 — automates lifecycle policy alignment with HIPAA retention
CostCenter	UTDCapstone2026 — for billing allocation

Apply a mandatory tagging policy via AWS Config rule required-tags. Any resource missing required tags should trigger a CloudWatch alarm and be flagged for immediate review.

Multi-Account Strategy (Recommended for Production)

For a production deployment, isolate environments using AWS Organizations with separate accounts:

- Management Account — billing, AWS Organizations SCPs, no workloads
- Production Account — live PHI data, strictest controls, limited access
- Staging Account — anonymized test data, mirrors prod configuration
- Development Account — synthetic data only, no PHI ever

Service Control Policies (SCPs) at the organization level enforce guardrails that cannot be overridden by any account admin — for example, blocking all non-US regions or preventing disabling of CloudTrail.

Identity & Access Management — Deep Dive

IAM Role Design for VV

Role Name	Permissions & Purpose
vv-sensor-ingest-role	s3:PutObject on raw/ prefix only. Used by the ingestion service. No read, no delete.
vv-model-pipeline-role	s3:GetObject on raw/ and processed/. s3:PutObject on predictions/ and models/. No delete.
vv-dashboard-read-role	s3:GetObject on dashboards/ and predictions/ only. Used by dashboard_app.py. No write.
vv-alert-writer-role	s3:PutObject on alerts/ only. Tightly scoped to alert engine service.
vv-admin-role	Full bucket access. Requires MFA. Used only for maintenance tasks. No programmatic access.
vv-audit-read-role	s3:GetObject on logs/ only. Used by compliance reviewers. Read-only, no data access.

IAM Permission Boundaries

Attach a Permission Boundary to all VV IAM roles. This acts as a maximum permissions ceiling — even if a role policy is misconfigured or escalated, it cannot exceed what the boundary allows.

- Define a boundary that restricts actions to s3:*, kms:Decrypt, kms:GenerateDataKey on VV-specific ARNs only
- Attach the boundary to every VV role at creation time
- Prevents privilege escalation even if an attacker compromises a role

AWS IAM Identity Center (SSO)

For teams with multiple members accessing VV data, use AWS IAM Identity Center instead of individual IAM users. Benefits:

- Single sign-on with your university or organizational identity provider (e.g., UTD Microsoft 365)
- Centralized access review — see who has access to what from one console
- Automatic access revocation when a team member's account is deactivated in the IdP
- Time-limited sessions — credentials expire automatically, no long-lived access keys

Secrets Management

Never store credentials, API keys, or database passwords in code, environment variables, or S3. Use AWS Secrets Manager:

- Store the S3 bucket name, KMS key ARN, and any API keys as secrets
- Enable automatic rotation for database credentials (if applicable)
- Access secrets programmatically via the Secrets Manager API — secrets never appear in logs
- Cost: ~\$0.40/secret/month — negligible for VV scale
- Audit all secret access via CloudTrail — every retrieval is logged

Network Security Architecture

VPC Design for VV

If VV runs any compute (EC2, Lambda, ECS) in AWS alongside S3, deploy it inside a Virtual Private Cloud with the following architecture:

- Private subnets for all compute — no public IP addresses on application servers
- Public subnet only for load balancers or NAT Gateway (if outbound internet needed)
- S3 VPC Endpoint (Gateway type) — all S3 traffic stays on the AWS network, never traverses public internet
- KMS VPC Endpoint — KMS calls for encryption/decryption also stay private
- Secrets Manager VPC Endpoint — secrets retrieval never leaves the VPC

Security Groups & NACLs

Component	Configuration
Application Security Group	Inbound: port 443 (HTTPS) from known IP ranges only. Outbound: S3 VPC Endpoint only. No port 22 (SSH) open to the internet.
Network ACL (NACL)	Stateless firewall at subnet level. Block all traffic from known malicious IP ranges. Allow 443 inbound, deny all else by default.
VPC Flow Logs	Enable on all VPCs. Log to S3 or CloudWatch Logs. Retain for 90 days minimum. Analyze with Athena for anomaly detection.

Component	Configuration
AWS WAF (if web-facing)	If <code>dashboard_app.py</code> is exposed via HTTPS, place AWS WAF in front. Enable AWS Managed Rules for Common Threats and Known Bad Inputs.

Data in Transit — Detailed Requirements

- TLS 1.2 minimum for all connections — TLS 1.3 strongly recommended
- S3 bucket policy must explicitly deny requests where `aws:SecureTransport` is false
- Disable legacy SSL/TLS cipher suites — enforce forward secrecy ciphers (ECDHE)
- Use AWS Certificate Manager (ACM) for TLS certificates — auto-renews, no manual management
- Enable HSTS (HTTP Strict Transport Security) if serving any web content

Compliance Automation & Continuous Monitoring

AWS Security Hub — HIPAA Standard

AWS Security Hub provides a centralized dashboard for security findings across your AWS account. Enable the HIPAA Security Rule standard to get automated checks against 160+ HIPAA-relevant controls.

- Activate Security Hub in all regions where VV resources exist
- Enable the AWS Foundational Security Best Practices standard and HIPAA standard
- Integrate findings with CloudWatch Events for automated remediation
- Review Security Hub findings weekly — address Critical and High findings within 72 hours

AWS Config Rules for HIPAA

Deploy these AWS Config rules to continuously monitor compliance. Non-compliant resources trigger SNS notifications:

Config Rule	What It Checks
<code>s3-bucket-public-read-prohibited</code>	No S3 bucket allows public read access
<code>s3-bucket-public-write-prohibited</code>	No S3 bucket allows public write access
<code>s3-bucket-server-side-encryption-enabled</code>	All S3 buckets have SSE enabled
<code>s3-bucket-ssl-requests-only</code>	S3 bucket policy denies non-HTTPS requests
<code>s3-bucket-versioning-enabled</code>	Versioning is active on all VV buckets
<code>kms-cmk-not-scheduled-for-deletion</code>	No KMS CMK is scheduled for deletion
<code>cloudtrail-enabled</code>	CloudTrail is active in all regions
<code>cloud-trail-encryption-enabled</code>	CloudTrail logs are encrypted with KMS

Config Rule	What It Checks
iam-no-inline-policy	No IAM users or roles use inline policies
iam-root-access-key-check	Root account has no active access keys
mfa-enabled-for-iam-console-access	MFA is enabled for all IAM users with console access
guardduty-enabled-centralized	GuardDuty is enabled and reporting

Amazon GuardDuty

GuardDuty is a threat detection service that continuously monitors for malicious activity and unauthorized behavior. Enable it in all regions — it analyzes CloudTrail, VPC Flow Logs, and DNS logs automatically.

- Detects: credential compromise, unusual API calls, S3 data exfiltration patterns, cryptocurrency mining
- Zero configuration required — enable and it begins detecting within minutes
- Cost: ~\$4–15/month for VV scale — one of the highest-value security controls available
- Integrate GuardDuty findings with Security Hub for unified view

Amazon Macie — PHI Auto-Detection

Macie uses machine learning to automatically discover and classify sensitive data in S3, including PHI patterns. Critical for verifying that only intended buckets contain health data.

- Detects: names, dates of birth, addresses, medical record numbers, health conditions in text
- Runs automated sensitive data discovery across all S3 buckets in the account
- Generates findings when PHI is detected in unexpected locations (e.g., a development bucket)
- Schedule weekly automated scans on all VV buckets

Third-Party Compliance Platforms

For teams that want a streamlined compliance dashboard without manually configuring every AWS control, these platforms automate HIPAA compliance monitoring and evidence collection:

Platform	Description & Fit for VV
Vanta	Automated HIPAA, SOC 2, and GDPR compliance. Integrates with AWS to continuously monitor controls. Generates audit-ready reports. Best for teams planning formal certification. ~\$1,000/year for small teams.
Drata	Similar to Vanta with strong AWS integration. Automates evidence collection for HIPAA audits. Good for capstone projects that may mature into startups.
Tugboat Logic	More affordable option for early-stage teams. Manages risk assessments, policies, and evidence. Good starting point before investing in Vanta/Drata.
AWS Audit Manager	Native AWS tool. Maps AWS usage to HIPAA controls automatically. Free to use (pay per assessment). Good option for staying within the AWS ecosystem.

Privacy by Design & Data Minimization

Core Privacy Principles Applied to VV

Privacy by Design means building privacy protections into the system architecture from the start — not bolting them on after the fact. For VV, this means:

- **Data Minimization** — collect only what is strictly necessary. Does the cloud storage need raw x/y/z readings, or only the derived posture classification? Consider storing only the output, not the raw sensor stream.
- **Purpose Limitation** — data collected for health monitoring should not be used for any other purpose without explicit consent. Document the stated purpose in your privacy policy and BAA.
- **Storage Limitation** — define and enforce retention periods. Do not keep PHI indefinitely. HIPAA requires 6 years for covered entities; the actual sensor data may need far less.
- **Accuracy** — implement data validation at ingestion to reject malformed or out-of-range sensor readings before they enter the PHI store.
- **Integrity and Confidentiality** — encryption, access controls, and audit logging as described throughout this document.

De-identification & Anonymization Options

If the full detail of VV data is not needed in the cloud (e.g., for model training or research), consider de-identifying the data before upload to remove HIPAA obligations entirely.

Technique	Description & VV Applicability
HIPAA Safe Harbor De-identification	Remove all 18 HIPAA identifiers including dates (except year), location below state, and any unique codes. Replace sensor UUIDs with non-linkable random IDs. Dates must be generalized to year only. After this, data is no longer PHI.
Expert Determination Method	A qualified statistician certifies that re-identification risk is very small. More flexible than Safe Harbor — allows retention of some detail. Requires documented expert analysis.
k-Anonymity	Generalize quasi-identifiers so each record is indistinguishable from at least k-1 others. For VV, this means grouping timestamps into time windows (e.g., hourly) and rounding z_height to 0.1m bins.
Differential Privacy	Add calibrated statistical noise to aggregated outputs (e.g., hourly posture summaries). Guarantees mathematical privacy bounds. AWS Clean Rooms supports differential privacy for data collaboration.
Synthetic Data Generation	Use a GAN or statistical model trained on VV data to generate synthetic sensor data with the same statistical properties but no connection to the real resident. Safe to use for model training and sharing.

ML Model Security & Integrity

Protecting Model Artifacts

The trained Random Forest model (.pkl file) and any associated preprocessing pipelines are sensitive assets. A compromised model could produce false predictions — missing real falls or generating false alerts — with serious consequences for resident safety.

- Store model files in a dedicated models/ S3 prefix with stricter access than general data
- Only the model pipeline IAM role should have read access; no direct human access in production
- Enable S3 Object Lock on model files — prevent any modification or deletion without explicit approval
- Hash all model files (SHA-256) at training time; verify hash before every load in production
- Version model files with timestamps and training run IDs — never overwrite, always create new versions

Model Versioning & Audit Trail

- Use MLflow or AWS SageMaker Model Registry to track model versions, training data, hyperparameters, and performance metrics
- Every prediction run should log: model version used, input data hash, output summary, timestamp
- Maintain a model card documenting: training data characteristics, performance by room and posture class, known limitations, intended use, and out-of-scope uses
- Schedule quarterly model performance reviews — alert if accuracy drops below threshold on new data

Adversarial & Integrity Risks

For a sensor-based health system, consider these attack vectors:

- Model poisoning — if retraining is automated, an attacker injecting malformed sensor readings could degrade model performance. Validate all training data before retraining.
- Sensor spoofing — a tampered radar sensor could send false z_height values to trigger or suppress alerts. Implement anomaly detection on incoming sensor streams.
- Pickle deserialization — .pkl files are executable. Never load a model file from an untrusted source. Verify the S3 object ETag matches the expected hash before loading.

Edge Processing Option — Reduce PHI Exposure

An alternative to sending raw sensor data to the cloud is to process the data locally on the VV Hub and only send de-identified summaries or alerts to cloud storage. This approach significantly reduces HIPAA exposure.

Architecture	Description
Full Cloud (current path)	All raw JSON and CSV files uploaded to S3. Maximum cloud functionality. All data subject to HIPAA. Requires full compliance stack described in this document.
Edge Processing + Cloud Alerts	VV Hub runs posture classification and alert logic locally. Only alert events and aggregated daily summaries are sent to S3. Raw sensor readings never leave the home network. Minimal PHI in cloud.
Edge Processing + Cloud Model Updates	Models trained in cloud on anonymized data. Predictions run at the edge. Only model files flow from cloud to hub. No PHI ever in cloud. Most privacy-preserving architecture.

i Edge Processing Recommendation

For a production deployment, Edge Processing + Cloud Alerts is the recommended architecture. It dramatically reduces HIPAA scope, lowers cloud storage costs, reduces latency for alerts, and maintains resident privacy. The VV Hub (Raspberry Pi or equivalent) handles real-time inference; the cloud receives only structured alert records and anonymized daily summaries.

Detailed Cost Estimates

VV Data Volume at Current Scale

Data Asset	Estimated Size & Growth
presence_data_4.json (raw)	~60 MB for 14 days / ~1.3 GB per year
sensor_data.csv (processed)	~23 MB for 14 days / ~600 MB per year
Model files (.pkl)	~1–5 MB, infrequent changes
EDA dashboard images (PNG)	~2 MB total, static
Alert records (CSV)	< 1 MB/month, very small
CloudTrail logs	~10–50 MB/month depending on API activity
Total estimated Year 1	~2–3 GB stored, ~500 MB transferred

AWS Monthly Cost Breakdown (Estimated)

Service	Estimated Monthly Cost
S3 Standard Storage (2 GB)	~\$0.05
S3 PUT/GET/LIST requests (~10,000/mo)	~\$0.05
S3 Intelligent-Tiering (archive tier)	~\$0.00 at this scale
KMS Customer Managed Key	~\$1.00/key/month + \$0.03/10,000 API calls

Service	Estimated Monthly Cost
CloudTrail (management events)	Free for first trail; \$2.00/100,000 data events
AWS Config (rules)	~\$2.00–4.00 for 12 rules
Amazon Macie (automated discovery)	~\$1.00–3.00/month at VV data volume
Amazon GuardDuty	~\$4.00–8.00/month
AWS Security Hub	~\$0.001/finding; ~\$1.00–3.00/month
VPC Endpoints (S3 Gateway type)	Free
CloudWatch Logs & Alarms	~\$1.00–3.00/month
TOTAL ESTIMATED	~\$12–25/month

Note: AWS offers a 12-month Free Tier for new accounts that covers S3 (5 GB), CloudWatch, and many other services at no cost. GuardDuty offers a 30-day free trial. For a capstone project, total costs may be near zero for the first year.

Additional Compliance Frameworks

NIST SP 800-66 — HIPAA Security Rule Implementation Guide

The National Institute of Standards and Technology publishes SP 800-66, the official guidance document for implementing the HIPAA Security Rule. Key sections relevant to VV:

- Section 4.1 — Risk Analysis: provides a step-by-step template for the required HIPAA risk assessment
- Section 4.14 — Audit Controls: specifies what activities must be logged and how long logs must be retained
- Section 4.22 — Transmission Security: details encryption requirements for ePHI in transit
- Download free at: csrc.nist.gov/publications/detail/sp/800-66/rev-2/final

HITRUST CSF

The HITRUST Common Security Framework is the most widely adopted security framework in the US healthcare industry. Many healthcare organizations require their technology partners to be HITRUST certified. While full HITRUST certification is complex, aligning with its control requirements is valuable.

- HITRUST maps to HIPAA, NIST, ISO 27001, and SOC 2 simultaneously
- A HITRUST e1 Assessment (entry level) covers 44 essential controls and is achievable for small teams
- Achieving HITRUST certification significantly increases credibility with healthcare enterprise customers

SOC 2 Type II

SOC 2 Type II is a third-party audit report confirming that your security controls operated effectively over a 6–12 month period. While not required by HIPAA, it is commonly requested by enterprise healthcare clients and investors.

- Covers: Security, Availability, Processing Integrity, Confidentiality, Privacy (Trust Service Criteria)
- Most relevant for VV if the system is commercialized or licensed to care facilities
- Platforms like Vanta or Drata can help prepare for SOC 2 audit in 3–6 months

GDPR Considerations

If any researchers, caregivers, or partner organizations based in the European Union interact with VV data, GDPR applies in addition to HIPAA. Key additional requirements:

- Lawful basis for processing — must have documented legal basis (consent, legitimate interest, vital interests) for each processing activity
- Data Subject Rights — right to access, rectification, erasure (right to be forgotten), and portability
- Data Protection Impact Assessment (DPIA) — required for systematic monitoring of individuals, which VV clearly constitutes
- 72-hour breach notification to supervisory authority (stricter than HIPAA's 60 days)
- Data Processing Agreement (DPA) required with AWS — distinct from the BAA

Vendor Lock-in & Portability Considerations

AWS is the recommended platform, but it is important to architect VV in a way that does not make migration prohibitively expensive if requirements change.

Risk	Mitigation Strategy
S3-specific APIs	Use standard S3-compatible APIs. Most competitors (Azure Blob, GCS) support S3-compatible interfaces, reducing migration friction.
KMS-encrypted data	If you migrate off AWS, your KMS-encrypted data must be decrypted first. Document the KMS key policy and keep a procedure for bulk re-encryption if needed.
AWS-specific services (Macie, GuardDuty)	These are AWS-proprietary. Document what each does so equivalent services can be sourced on the new platform (e.g., Microsoft Defender for Cloud on Azure).
CloudTrail log format	CloudTrail logs are JSON and can be exported to S3. Maintain a copy in a neutral format for portability.
IAM policies	Document IAM policies in infrastructure-as-code (Terraform or CloudFormation). These are portable to other IAM systems with minor adaptation.

Incident Response — Expanded Procedures

Response Playbooks

Pre-defined playbooks reduce response time and prevent panic-driven mistakes during a security incident. Develop and test these before go-live:

Playbook 1: Unauthorized S3 Access

7. Detect: GuardDuty finding Policy:S3/BucketBlockPublicAccessDisabled or UnauthorizedAccess:IAMUser/MaliciousIPCaller
8. Contain: Immediately revoke the compromised IAM credential via AWS Console or CLI
9. Preserve: Take a snapshot of CloudTrail logs for the past 7 days before any remediation
10. Assess: Determine which S3 objects were accessed, downloaded, or modified
11. Notify: If PHI was accessed, initiate breach notification procedure (see Section 8)
12. Remediate: Rotate all credentials, review and tighten IAM policies, update S3 bucket policy
13. Document: Record timeline, impact, and remediation steps in incident log

Playbook 2: Ransomware / Data Encryption Attack

14. Detect: CloudWatch alarm on unusual PutObject volume or new KMS key creation outside normal patterns
15. Contain: Block offending IP/role immediately. Do NOT pay ransom.
16. Recover: S3 Versioning and Object Lock mean you can restore previous versions of all objects — this is your primary defense against ransomware
17. Assess: Identify the attack vector (compromised credential, misconfigured bucket policy)
18. Remediate: Restore from last-known-good version. Patch the vulnerability. Reset all credentials.

Playbook 3: Accidental PHI Exposure (Misconfigured Bucket)

19. Detect: Macie finding or AWS Config rule violation s3-bucket-public-read-prohibited
20. Contain: Immediately enable all Block Public Access settings on the bucket
21. Assess: Use S3 Server Access Logs to determine if any external party accessed the data during the exposure window
22. Notify: If external access is confirmed, this is a reportable breach — follow notification timelines
23. Remediate: Review and update all bucket policies and ACLs. Run Macie scan to confirm no other exposed buckets.

Annual Compliance Review Checklist

HIPAA requires covered entities to review and update their security policies and procedures periodically, and whenever significant operational or environmental changes occur. Conduct this review annually at minimum.

Annual Review Tasks

- ☐ Repeat HIPAA Risk Analysis — assess any new threats, vulnerabilities, or system changes
- ☐ Review and update all IAM roles and policies — remove unused roles, tighten permissions
- ☐ Rotate all long-lived credentials (API keys, service account passwords)
- ☐ Review CloudTrail and S3 access logs for anomalous patterns from the prior year
- ☐ Test disaster recovery procedures — restore a sample dataset from backup
- ☐ Review and update the Business Associate Agreement with AWS if services have changed
- ☐ Retrain the posture classification model if data drift is detected
- ☐ Review Security Hub and GuardDuty findings from the prior year — confirm all criticals resolved
- ☐ Update the Notice of Privacy Practices if any data practices have changed
- ☐ Conduct workforce security training refresher
- ☐ Review data retention schedule — securely delete data past its retention period
- ☐ Update incident response playbooks based on lessons learned
- ☐ Review AWS cost and usage — ensure no unintended resources are running

Decision Summary & Recommendation

★ Recommended Path: AWS S3 with Full HIPAA Controls

Platform: Amazon Web Services (AWS) — us-east-1 primary, us-west-2 replication
Storage: Amazon S3 with versioning, Object Lock, and SSE-KMS (CMK)
Encryption: SSE-KMS Customer Managed Key + HTTPS-only bucket policy
Access: IAM roles (least privilege) + IAM Identity Center + MFA Delete + VPC Endpoints
Monitoring: CloudTrail + S3 Access Logs + GuardDuty + Macie + Security Hub + Config Rules
Compliance: BAA via AWS Artifact + AWS Audit Manager HIPAA assessment
Architecture: Edge Processing + Cloud Alerts (preferred) OR Full Cloud with full compliance stack
Estimated Cost: ~\$12–25/month; near zero in Year 1 with AWS Free Tier

AWS provides the most mature HIPAA program, the broadest set of compliant services, and the strongest native tooling for healthcare data security. The controls described in this document, implemented correctly, satisfy the HIPAA Security Rule's administrative, physical, and technical safeguard requirements.

The edge processing architecture (process locally, push only alerts and summaries to cloud) is the recommended long-term approach for production — it minimizes PHI exposure, reduces cloud costs, improves response latency, and gives the resident greater privacy assurance.

i For the Capstone Submission

If this system is not yet in production with a real named resident, strict HIPAA obligations may not apply to the current research prototype. However, adopting these controls now ensures the system is production-ready and demonstrates responsible data engineering practice — important criteria for a capstone project in the healthcare AI space. Document your architecture decisions and security rationale; reviewers will recognize the maturity of a team that thought through compliance proactively.